

How to Guide: Access to Your Personal Information [General version]

In Australia, individuals have a right to request access to their personal information under Australian Privacy Principle 12 (part of Australia's Privacy Act). This right has existed for a long time, however there is a lack of public awareness about this right in Australia.

It is important to note that this right only applies to organisations that are covered by the Australian Privacy Act. This includes most government agencies, organisations with an annual turnover of more than \$3 million and certain small businesses such as private sector health service providers, organisations that sell or purchase personal information and a few other types of businesses. See

more: <https://www.oaic.gov.au/privacy/privacy-legislation/the-privacy-act/rights-and-responsibilities#who-has-responsibilities-under-the-privacy-act>

In the UK and EU, 'data subject rights', as they are known in the UK and EU under the GDPR, are commonly exercised by people who wish to understand more about/hold organisation accountable for the processing of their personal information. Requesting access to personal information can also be a tool used to hold companies to account and reveal unlawful behaviour.

We at Digital Rights Watch want the Australian public to be aware of their rights in relation to the processing of their personal information and want to advocate for further rights such as the right to request deletion which is currently not available in Australia. See our campaign on this, here: <https://digitalrightswatch.org.au/campaigns/right-to-delete/>

This guide is intended to provide you with an overview of your right to access personal information under Australian privacy law and answer any questions you may have. Please note that under Australian privacy law, this right also applies to government agencies (with certain exceptions and operates alongside Freedom of Information requests). We have however made this guide focused on private sector organisations. It may still be useful for public agencies, but please read more about making these requests to public agencies

here: <https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-12-app-12-access-to-personal-information>

Three Steps to Requesting Your Personal Information

1. Make the request
2. Verify your ID if requested and you feel comfortable (note that the law doesn't require this but OAIC guidance confirms that organisations should verify ID with the minimum amount of personal information needed to establish an individual's identity)
3. Await response (and follow-up if not received within 30 days)

Step 1: Make the request

Firstly, you should contact the organisation that holds your personal information to request access. Only you or another person you have authorised, such as a legal guardian or authorised agent, can make the request. An organisation or agency must be satisfied the request came from you or a person you authorised.

There is no specific format that you need to use. You can simply ask for your information even over a phone call, however we recommend putting it in writing so you have a record of the request. If an organisation requests you to fill in a specific form, you don't have to: you can exercise your right of access in any form you deem fit.

You may be asked to put your request in writing and for information that identifies you. If so, the OAIC recommends that you include:

- your name and contact details
- the personal information you want to access
- how you'd like access to the personal information (such as receiving a copy by email or post, or if you just want to look at the information)
- if you authorise a person or organisation to access the personal information on your behalf.

Step 2

The relevant organisation has to be satisfied that a request for personal information under APP 12 is made by the individual concerned, or by another person who is authorised to make a request on their behalf, for example, as a legal guardian or authorised agent.

Sometimes, organisations will ask you to provide a copy of your ID to verify your identity.

Guidance from the OAIC clarifies that the steps appropriate to verify an individual's identity will depend on the circumstances. In particular, whether the individual is already known to or readily identifiable by the

organisation, the sensitivity of the personal information and the possible adverse consequences for the individual of unauthorised disclosure. It is made clear in OAIC guidance that the minimum amount of personal information needed to establish an individual's identity should be sought. Where possible, the personal information should be sighted rather than copied or collected for inclusion in a record. For example, in a face-to-face dealing with an individual, an entity may be able to record that an identity document was sighted without copying the document. In a telephone contact it may be adequate to request information that can be checked against records held by the entity.

If you feel uncomfortable by the types of additional personal information that an organisation is requesting (for example because they are asking you for information that you didn't previously share with them), you can of course refuse and ask them to verify your ID in a less invasive way – referring to the OAIC guidance on this: <https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-12-app-12-access-to-personal-information> (see 'Verifying an Individual's Identity' section)

Step 3

An organisation must respond to a request for access to personal information within a reasonable period. The OAIC has issued guidance which provides that it considers 30 days is a reasonable period.

In practice, sometimes organisations will engage in back and forth questions asking for further details on what personal information you are after etc. This can be frustrating but you can remind the organisation of their legal obligation under APP 12.

An organisation must give you access to your personal information in the way you asked to access it, if it is reasonable and practical to do so. For example, you may ask to access your personal information by receiving a copy in an email or by post, by being given information over the phone or by inspecting the information in person. The OAIC has noted that if the organisation can't give you access to your personal information in the way you requested, they must try to give you access in a way that meets both your and their needs.

If you do not receive a response within 30 days, you can follow-up with the organisation and in instances of still no response, there are various complaint mechanisms available. The OAIC has noted that these complaint avenues should include:

- a complaint should first be made in writing to the organisation and the entity should be given a reasonable time (usually 30 days) to respond

- a complaint may then be taken to a recognised external dispute resolution scheme of which the entity is a member (if any), and
- lastly, a complaint may be made to the OAIC.

In the UK and EU we have seen these requests be used successfully to hold companies to account and reveal unlawful behaviour.

For more information on making a complaint,
see: <https://www.oaic.gov.au/privacy/privacy-complaints/lodge-a-privacy-complaint-with-us>

FAQs

Why would I request my personal information?

There are many benefits to requesting access to your personal information. It is easy to feel very powerless in today's digital and data driven world in relation to how our information is used, but exercising your right to access can help you get back a certain extent of control over what companies are doing with your personal information. Generally, requesting access can:

- enable you to understand how your digital footprint is being used and give you greater control over your data
- provide transparency around any automated decision-making processes, profiling practices and risk scoring systems
- increase accountability for organisations
- help you identify any incorrect information
- reduce black box data practices

In Europe and the UK, the right to access personal data under the GDPR has been used quite strategically and successfully to uncover data processing practices and litigate them.

The most prominent case is arguably that of Max Schrems, who first submitted an access request to Facebook in 2011, to receive a 1,200 pages long document featuring personal information he had no idea Facebook was processing. This led to the first complaints raised in front of the Irish supervisory authority, which eventually led to rulings from the Court of Justice of the European Union (CJEU) that shaped EU rules on transatlantic transfers of personal data.¹

French journalist, Judith Duportail made a data subject access request to Tinder and received 800 pages of data back containing information such as Facebook likes, links to where Instagram photos would have been had she not previously deleted the associated account, her education, the age-rank of men she was interested in, how many Facebook friends she had, when and where every online conversation with every single match happened¹.

David Carroll, an academic, used a subject access request to try and find out whether Cambridge Analytica the controversial political consulting firm that built profiles on voters to influence the 2016 US election and

1

<https://www.theguardian.com/technology/2017/sep/26/tinder-personal-data-dating-app-messages-hacked-sold>

Brexit referendum². Their failure to comply resulted in regulatory actions and fines.

More recently, access requests towards online gambling platforms and profiling companies have helped shedding light on their extensive tracking and profiling practices, including in relation to sensitive personal information, lack of transparency, and other unlawful processing practices undertaken to market addictive products to customers and exploit their fragility to keep them gambling.²

Even when they are not answered or are answered only partially, access requests can still lead to landmark rulings that uphold digital rights. In other CJEU rulings, the exercise of the right to access by individuals has led the Court to reiterate that this right cannot be fulfilled by simply providing a summary of the personal information held by an organisation, but needs to include all the data points processed.³

We have also seen organisations fined globally for not properly complying with data subject access requests. See for example: <http://www.privacyinternational.org/examples/cambridge-analytica>

Open Rights Group has a range of case studies available about how access requests have been used by minority groups, civil society and trade unions to affect change: <https://www.openrightsgroup.org/how-gdpr-stops-discrimination-and-protects-equalities/>

Do organisations have to comply or can they refuse to comply?

As long as an organisation is covered by the Australian Privacy Act – this is the case for organisations with an annual turnover of more than \$3 million, as well as certain small businesses including private sector health service providers, organisations that sell or purchase personal information and a few other types of businesses – they must address your request.

There are however, 10 exceptions where organisations do not need to comply with access requests. These are set out below:

2

<https://www.theguardian.com/uk-news/2019/jan/09/cambridge-analytica-owner-scl-elections-fined-ignoring-data-request>

- the organisation believes that giving you access may endanger the life, health or safety of any individual, or endanger public health or safety
- giving you access would have an unreasonable impact on the privacy of other individuals
- your request is frivolous or vexatious
- your personal information is part of existing or anticipated legal proceedings between you and the organisation.
- giving you access would reveal the intentions of the organisation in relation to negotiations with the individual in such a way as to prejudice those negotiations
- giving you access would be unlawful
- denying access is required or authorised by or under an Australian law or a court/tribunal order
- the organisation has reason to suspect that unlawful activity, or misconduct of a serious nature, that relates to the organisation's functions or activities has been, is being or may be engaged in and giving access would be likely to prejudice the taking of appropriate action in relation to the matter
- giving you access would be likely to prejudice one or more enforcement related activities conducted by, or on behalf of, an enforcement body
- giving you access would reveal evaluative information generated within the organisation in connection with a commercially sensitive decision-making process

Organisations may also choose to redact some information (such as information about a third person to protect their privacy).

If an organisation or agency refuses you access to your personal information under Australian privacy law, they must tell you in writing their reasons for refusing and how you can make a complaint.

How long do organisations have to comply?

An organisation must respond to a request for access to personal information within a reasonable period. The OAIC has issued guidance which provides that it considers 30 days is a reasonable period.

Is it free or can organisations charge me?

Requesting your personal information is free. However, an organisation may charge for providing you access, but the OAIC has clarified that this charge can't be excessive. The organisation must tell you there's a charge and explain the reasons for it. Costs may include for example:

- staff searching for, locating and retrieving the requested information, and deciding which personal information is relevant to the request
- staff reproducing and sending the personal information
- the postage or materials involved in giving access
- using an intermediary, if necessary.

However, an organisation cannot shift costs to the individual making the request in case they need to obtain legal advice in relation to the request, or fix shortcomings in their information management systems.

Do I have any other rights in respect of my personal information?

Under Australia's Privacy Act, in addition to the right of access under APP 12, you also have the right to correct any incorrect information about yourself under APP 13.

In addition, and quite unique to Australian privacy law, you also should have the option of not identifying yourself or using a pseudonym when interacting with organisations covered by the Australian Privacy Act, subject to certain exceptions under APP 2.

However, it has been suggested that additional individual rights be introduced as part of privacy reform in Australia to bring it in line with international data protection best practice.

This should include the right to request deletion of data (see our campaign on this <https://digitalrightswatch.org.au/campaigns/right-to-delete/>), the right to object to processing, the right to data portability, the right to not be subject to automated decision-making and the right to request certain information regarding the processing.

Template Personal Information Requests

Below we have provided a template option that can be used and tailored as needed depending on your circumstances. While it can be helpful to be prescriptive about the information that you require, you may also wish to just ask for “all personal information” that the relevant organisation holds about you.

Please note that organisations may ask for your ID for verification purposes (although OAIC guidance makes clear that they should do so by requesting the minimal amount of personal information). The law requires organisations to respond within a “reasonable period” and OAIC guidance has clarified that this is within 30 days of receiving the request.

Dear [organisation name]

My name is [insert name]. I am a [existing/previous] customer of [insert organisation name].

I would like to make a request under the Australian Privacy Act, specifically Article 12 of the Australian Privacy Principles to access the personal information that you hold about me as an organisation.

Could you also please provide:

- A copy of the relevant privacy policy that governs the processing of my personal data pursuant to Australian Privacy Principle 1
- Confirmation of where my personal data is stored and which parties have access to it
- [insert any other specific information or questions you want to include]

I look forward to receiving your timely response, which I understand should be received within 30 days in accordance with OAIC guidance.

Kind regards
[insert your name]